

Medidas de seguridad pasiva

SEGURIDAD Y ALTA DISPONIBILIDAD

Pautas de seguridad informática

- Las pautas de seguridad informática son esenciales para proteger los sistemas, datos y recursos en cualquier entorno digital. A través de estándares reconocidos internacionalmente, como ISO/IEC 27001, el NIST Cybersecurity Framework y los CIS Controls, las organizaciones pueden implementar medidas que mitiguen los riesgos y amenazas cibernéticas.

Principales estándares de seguridad informática:

- **ISO/IEC 27001:** Es un estándar internacional que establece cómo gestionar la seguridad de la información de una organización. Su objetivo es proteger la confidencialidad, integridad y disponibilidad de la información. Incluye la gestión de riesgos y la implementación de controles basados en estos riesgos.



Sistema de gestión de
seguridad de la información



Principales estándares de seguridad informática:

- **NIST Cybersecurity Framework:** Este marco, ampliamente utilizado, se basa en cinco pilares:
- **Identificar:** Conocer qué activos y datos necesitan protección.
- **Proteger:** Implementar medidas de seguridad para salvaguardar los sistemas.
- **Detectar:** Tener mecanismos que detecten incidentes de seguridad.
- **Responder:** Estar preparados para actuar cuando se detecten amenazas.
- **Recuperarse:** Planificar cómo volver a la normalidad tras un ataque.



Principales estándares de seguridad informática:

- CIS Controls: Son un conjunto de controles de seguridad priorizados, que proporcionan una guía sobre qué medidas tomar primero para mejorar la seguridad informática de una organización. Se organizan en tres categorías: básicos, fundamentales y organizacionales.



Principales estándares de seguridad informática:

- Las NIS2 son la segunda versión de la **Directiva sobre la Seguridad de las Redes y los Sistemas de Información** de la Unión Europea, que se conoce comúnmente como la Directiva NIS (Network and Information Security Directive). Esta actualización fue adoptada en 2022 con el fin de mejorar la resiliencia y la seguridad de las redes y sistemas de información dentro de la UE, y aborda las lecciones aprendidas desde la primera directiva, que fue implementada en 2016.



Principales estándares de seguridad informática:

- **Objetivos principales de la NIS2:**

1. **Mejorar la ciberseguridad en la UE:** La NIS2 tiene como objetivo fortalecer la seguridad de las infraestructuras críticas y servicios esenciales en Europa. Esto incluye sectores como la energía, el transporte, la salud, la banca, las infraestructuras digitales, la gestión del agua y los servicios de emergencia.
2. **Establecer requisitos mínimos de seguridad:** La directiva exige que las organizaciones implementen medidas de ciberseguridad más estrictas y mantengan planes de acción en caso de incidentes. Estas medidas incluyen políticas de gestión de riesgos, respuestas a incidentes, gestión de crisis y recuperación de desastres.
3. **Ampliar el alcance de la directiva:** NIS2 amplía el ámbito de aplicación de la directiva original, abarcando un mayor número de sectores y organizaciones, incluyendo proveedores de servicios digitales como las plataformas de redes sociales, los servicios de computación en la nube y los proveedores de telecomunicaciones.
4. **Mejorar la cooperación entre los Estados miembros:** La directiva NIS2 busca mejorar la coordinación entre los Estados miembros de la UE en términos de intercambio de información y respuesta a incidentes de ciberseguridad. También establece un marco para la colaboración más efectiva con entidades privadas en la lucha contra las amenazas cibernéticas.
5. **Fortalecer la supervisión y la aplicación:** Los Estados miembros deberán supervisar el cumplimiento de la NIS2 de manera más estricta y asegurarse de que las organizaciones que no cumplan con los requisitos sean sancionadas adecuadamente.

Principales estándares de seguridad informática:

- **Cambios clave respecto a la primera directiva NIS:**
- **Aumento del número de sectores cubiertos:** NIS2 incluye más sectores económicos que la versión anterior. Por ejemplo, se incluyen ahora los servicios digitales esenciales, como los proveedores de DNS, de servicios de nube y las plataformas en línea.
- **Requisitos de notificación:** Las organizaciones afectadas por la NIS2 deben notificar incidentes de seguridad significativos dentro de plazos establecidos (generalmente 24 a 72 horas), lo que permite una respuesta más rápida a nivel nacional y europeo.
- **Sanciones más estrictas:** Las multas por incumplimiento pueden ser bastante altas, con sanciones que pueden llegar hasta el 2 % del volumen de negocios global anual de la empresa.

Principales estándares de seguridad informática:

- ¿A quién afecta la NIS2?
- Los sectores clave a los que afecta la NIS2 incluyen:
 - Energía
 - Agua potable y gestión de aguas residuales
 - Sanidad
 - Transporte
 - Banca y mercados financieros
 - Infraestructuras digitales (centros de datos, operadores de telecomunicaciones, proveedores de servicios en la nube, redes sociales)

Principales estándares de seguridad informática:

- **Impacto de no seguir las pautas de seguridad:**
- El informe de **Verizon 2020** señala que el 85 % de las brechas de seguridad fueron resultado de ataques que podrían haberse evitado si se hubieran seguido pautas básicas de seguridad. Esto demuestra la importancia de seguir buenas prácticas, como el uso de contraseñas seguras, la actualización de sistemas y la capacitación en ciberseguridad.
- Las pautas de seguridad son, por tanto, la primera línea de defensa en la protección contra ataques cibernéticos, y su correcta adopción y cumplimiento puede marcar la diferencia entre sufrir o prevenir un ataque.

ADOPCION DE PAUTAS DE SEGURIDAD

- La adopción de pautas de seguridad informática es un proceso clave para fortalecer la protección de los sistemas y la información dentro de una organización. Esto requiere un enfoque integral que no solo involucre a los departamentos técnicos, sino también a la alta dirección y a todos los empleados. Aquí te dejo un desglose más detallado de los puntos clave para asegurar una correcta implementación

ADOPCION DE PAUTAS DE SEGURIDAD

Evaluación de riesgos

- **Identificación de riesgos:** Es esencial analizar las amenazas potenciales que enfrenta la organización, tanto internas (empleados, sistemas desactualizados) como externas (ataques cibernéticos, desastres naturales). Esta evaluación debe cubrir tanto la tecnología como los procesos y personas involucradas.
- **Impacto y probabilidad:** Clasificar los riesgos según su probabilidad de ocurrencia y el impacto que tendrían en la organización. Esto permite priorizar los esfuerzos de seguridad en las áreas más vulnerables.
- **Plan de gestión de riesgos:** Definir un plan que establezca cómo mitigar, transferir o aceptar riesgos en función de su evaluación.

ADOPCION DE PAUTAS DE SEGURIDAD

Diseño y arquitectura segura

- **Infraestructura desde el inicio:** Diseñar redes y sistemas con seguridad en mente desde el principio (seguridad por diseño), aplicando técnicas como la **segmentación de redes** para limitar el acceso a diferentes partes de la infraestructura.
- **Protección de puntos críticos:** Asegurar que todos los puntos de entrada y salida de datos, como firewalls, gateways y routers, estén adecuadamente protegidos.
- **Cifrado de datos:** Implementar cifrado en reposo y en tránsito para garantizar que los datos sensibles estén protegidos en caso de brechas o interceptaciones.
- **Principio de mínimo privilegio:** Asegurarse de que los usuarios y sistemas solo tengan acceso a la información y recursos que necesitan para realizar sus funciones.

ADOPCION DE PAUTAS DE SEGURIDAD

Políticas y procedimientos

- **Políticas claras y accesibles:** Es fundamental crear políticas documentadas sobre temas clave como el acceso a sistemas, el uso aceptable de dispositivos, la gestión de contraseñas y la instalación de software.
- **Actualización de sistemas:** Desarrollar un procedimiento riguroso para la gestión de actualizaciones y parches de software y hardware, asegurándose de que los sistemas estén siempre protegidos contra las vulnerabilidades conocidas.
- **Respuesta a incidentes:** Definir procedimientos específicos para responder a incidentes de seguridad, incluyendo la identificación, contención, erradicación y recuperación del incidente, junto con la notificación a las partes relevantes.

ADOPCION DE PAUTAS DE SEGURIDAD

Capacitación y concienciación

- **Formación periódica:** Los empleados deben recibir capacitaciones regulares sobre cómo proteger la información, detectar amenazas como phishing y seguir las políticas de seguridad. Esto también fomenta una cultura de "conciencia de ciberseguridad".
- **Simulacros y pruebas:** Realizar simulacros de incidentes de seguridad (como ataques simulados de phishing) para evaluar la preparación de los empleados y mejorar sus habilidades para identificar y reaccionar ante amenazas.
- **Cultura de seguridad:** Involucrar a toda la organización en la seguridad. Cuando los empleados comprenden la importancia de la seguridad, actúan como la primera línea de defensa.

ADOPCION DE PAUTAS DE SEGURIDAD

Monitoreo y mejora continua

- **Monitoreo constante:** Implementar soluciones de detección de intrusos y monitoreo en tiempo real para detectar actividades sospechosas en la red, como accesos no autorizados o movimientos inusuales de datos.
- **Auditorías y pruebas de penetración:** Realizar auditorías periódicas para evaluar el estado de la seguridad, y llevar a cabo pruebas de penetración para identificar vulnerabilidades que podrían ser explotadas por atacantes.
- **Actualización y adaptación:** Revisar y actualizar las medidas de seguridad de manera constante para adaptarse a las nuevas amenazas, tecnologías emergentes y cambios en el entorno organizacional.

Impactos y repercusión

Protección de la información sensible

- **Confidencialidad, integridad y disponibilidad:** Las pautas de seguridad establecen medidas que garantizan que la información se mantenga privada (confidencialidad), sea precisa y no alterada (integridad) y esté disponible para quienes la necesiten (disponibilidad). Esto es esencial para evitar fugas de datos, robo de propiedad intelectual o manipulación no autorizada de información, lo que puede dañar gravemente la operación de la organización y su reputación.
- **Cumplimiento con estándares de seguridad:** Implementar cifrado, segmentación de redes y control de accesos robustos son ejemplos de prácticas que ayudan a proteger datos sensibles, desde información financiera hasta datos personales.

Impactos y repercusión

Prevención de ataques cibernéticos

- **Reducción de la superficie de ataque:** Al aplicar medidas como firewalls, sistemas de detección de intrusiones y mecanismos de autenticación multifactor, se dificulta el acceso no autorizado a la red y se minimizan las oportunidades para los atacantes.
- **Mitigación de riesgos:** La adopción de controles de seguridad reduce la probabilidad y el impacto de ataques cibernéticos, tales como ransomware, phishing, DDoS o malware. Estas pautas, al ser preventivas, limitan el daño potencial que los ciberdelincuentes podrían causar.

Impactos y repercusión

Cumplimiento normativo y legal

- **Regulaciones y estándares:** Cumplir con las pautas de seguridad garantiza que una organización esté alineada con regulaciones como el **Reglamento General de Protección de Datos (GDPR)** en Europa, **HIPAA** en el ámbito sanitario, o la ya mencionada **NIS2** en la UE. El incumplimiento de estas regulaciones puede resultar en multas considerables y sanciones legales.
- **Evitar sanciones:** Muchas organizaciones se enfrentan a multas o sanciones por no cumplir con los requisitos legales de seguridad de la información. Cumplir con estos requisitos no solo protege la información, sino que también garantiza la conformidad con las leyes y normativas.

Impactos y repercusión

Continuidad del negocio

- **Resiliencia frente a incidentes:** Adoptar medidas de seguridad robustas, como la creación de copias de seguridad, la planificación de la recuperación ante desastres y la implementación de sistemas redundantes, permite a las empresas minimizar el impacto de incidentes imprevistos.
- **Minimización del tiempo de inactividad:** La detección temprana de intrusiones y las respuestas rápidas ante incidentes garantizan que los sistemas críticos se mantengan en funcionamiento o se recuperen rápidamente, evitando interrupciones prolongadas que pueden resultar en grandes pérdidas financieras.
- **Planes de contingencia:** Contar con políticas de respuesta a incidentes y protocolos claros facilita la capacidad de la organización para operar incluso durante y después de un ataque.

Impactos y repercusión

Confianza y reputación

- **Compromiso con la seguridad:** Las organizaciones que demuestran un fuerte compromiso con la seguridad atraen mayor confianza de sus clientes, socios comerciales y partes interesadas. Esto fortalece las relaciones comerciales y mejora la reputación pública.
- **Fidelización de clientes:** Los clientes tienden a mantenerse leales a las empresas que gestionan adecuadamente su información personal y demuestran ser responsables en términos de seguridad.
- **Diferenciación competitiva:** En mercados altamente competitivos, contar con certificaciones de seguridad o demostrar cumplimiento de estándares internacionales de seguridad puede ser un factor diferenciador clave para atraer clientes y socios.

Impactos y repercusión

Ahorro de costos

- **Prevención de incidentes costosos:** Aunque la implementación inicial de medidas de seguridad requiere una inversión, el ahorro a largo plazo es considerable. Los incidentes de seguridad pueden acarrear costos elevados, incluyendo recuperación de datos, restauración de sistemas comprometidos, multas por incumplimiento y pérdida de ingresos debido a la interrupción de servicios.
- **Reducción del riesgo financiero:** Al evitar ataques y mitigar su impacto, las organizaciones no solo protegen sus activos, sino que también evitan los gastos adicionales asociados a demandas, pérdidas operacionales o daño a su reputación.
- **Protección frente a litigios:** Cumplir con normativas y pautas de seguridad reduce el riesgo de litigios, ya que las organizaciones pueden demostrar que han tomado las medidas necesarias para proteger los datos de los usuarios.

Seguridad física y ambiental

Acceso físico restringido

- **Control de acceso:** Se deben implementar medidas que limiten el acceso físico solo a personal autorizado. Esto puede incluir:
 - **Tarjetas de acceso:** Uso de credenciales para permitir o restringir el acceso a áreas sensibles, como salas de servidores.
 - **Autenticación biométrica:** Huellas dactilares, reconocimiento facial o de retina para garantizar que solo personas autorizadas ingresen.
 - **Vigilancia por video:** Cámaras de seguridad para monitorear en tiempo real quién accede a las áreas críticas y detectar cualquier intento de acceso no autorizado.
 - **Guardias de seguridad:** En áreas altamente sensibles, la presencia de personal de seguridad puede disuadir accesos no autorizados.

Seguridad física y ambiental

Protección contra intrusiones físicas

- **Barreras físicas:** Es importante contar con medidas que impidan accesos no autorizados, como:
 - **Cercas y puertas de seguridad:** Para controlar el perímetro de las instalaciones.
 - **Sistemas de alarmas:** Que alerten en caso de intentos de intrusión o acceso no autorizado.
 - **Sensores de movimiento:** Para detectar cualquier actividad inusual dentro de áreas restringidas.
- **Supervisión constante:** Ya sea mediante **cámaras de seguridad** o **vigilancia física**, es fundamental contar con sistemas de monitoreo que operen las 24 horas para garantizar la seguridad continua de las instalaciones.

Seguridad física y ambiental

Respaldo y protección de datos físicos

- **Almacenamiento seguro:** Los datos que no se encuentran en sistemas informáticos, como copias de seguridad en discos duros o documentos impresos, deben almacenarse de manera segura. Algunas medidas incluyen:
 - **Cajas fuertes:** Para almacenar datos físicos altamente sensibles o copias de seguridad.
 - **Salas con control de acceso:** Espacios dedicados para el almacenamiento de dispositivos y documentos que cuentan con sistemas de seguridad estrictos.
- **Políticas de gestión de documentos:** Es importante establecer políticas para asegurar que los documentos físicos sean gestionados de manera adecuada y destruidos de forma segura cuando ya no sean necesarios.
- **Destrucción segura de documentos:** El uso de trituradoras de papel para destruir documentos sensibles es una práctica básica pero fundamental.

Seguridad física y ambiental

Protección contra desastres y fallas ambientales

- **Sistemas de protección contra incendios:** Implementar sistemas de detección y extinción de incendios es crucial en áreas donde se almacena equipo crítico. Estos sistemas pueden incluir:
 - Detectores de humo y fuego: Para la detección temprana de un posible incendio.
 - Rociadores automáticos o sistemas de extinción por gas: Para apagar incendios sin dañar los equipos electrónicos.
- **Sistemas de alimentación ininterrumpida (SAI):** Estos dispositivos aseguran que, en caso de un corte de energía, los sistemas informáticos críticos continúen funcionando hasta que se restablezca la energía o se apague el sistema de manera segura.
- **Control de temperatura y humedad:** Los equipos informáticos son sensibles a las condiciones ambientales, por lo que es necesario contar con sistemas de climatización que mantengan la temperatura y la humedad dentro de rangos seguros para evitar sobrecalentamientos o fallas en los dispositivos.
- **Copia de seguridad fuera del sitio:** Para proteger los datos frente a desastres naturales o fallas graves, se recomienda tener copias de seguridad en ubicaciones remotas, asegurando la recuperación de la información en caso de una pérdida total de los sistemas locales.

Seguridad física y ambiental

Eliminación segura de dispositivos

- **Borrado seguro de datos:** Antes de deshacerse de dispositivos como discos duros, es crucial eliminar completamente cualquier dato almacenado utilizando métodos de **borrado seguro**, como la sobrescritura múltiple de datos, para evitar la recuperación de información.
- **Destrucción física de dispositivos:** En algunos casos, la mejor manera de garantizar que los datos no puedan recuperarse es destruir físicamente el dispositivo, como romper discos duros o triturar dispositivos de almacenamiento.
- **Reciclaje seguro:** Los dispositivos electrónicos deben ser eliminados de manera responsable, asegurando que cualquier componente que pueda contener datos sensibles sea gestionado adecuadamente por empresas especializadas en el reciclaje seguro de tecnología.

Ubicación y protección física de los equipos y servidores

Ubicación estratégica

- **Sala de servidores dedicada:** Los servidores y equipos críticos deben estar en una sala dedicada, diseñada específicamente para este propósito, conocida como **data center** o **sala de servidores**. Debe estar ubicada en áreas alejadas de posibles riesgos, como zonas de alto tráfico, ventanas expuestas o áreas propensas a inundaciones, incendios o terremotos.
- **Zonas seguras:** Si es posible, ubicar las salas de servidores en pisos intermedios (evitar plantas bajas, para prevenir inundaciones, y los últimos pisos, que pueden ser vulnerables a tormentas).
- **Protección perimetral:** Cercar las áreas críticas o restringir el acceso a través de barreras físicas para reducir las amenazas externas.

Ubicación y protección física de los equipos y servidores

Control de accesos

- **Acceso restringido:** Implementar **sistemas de control de acceso** para limitar el ingreso únicamente al personal autorizado. Algunos de los métodos recomendados incluyen:
 - **Tarjetas de identificación con acceso:** Solo quienes tienen permisos adecuados pueden ingresar a la sala de servidores.
 - **Sistemas biométricos:** El uso de reconocimiento de huellas dactilares, escáneres de retina o reconocimiento facial mejora la seguridad, asegurando que solo el personal específico pueda ingresar.
 - **Llaves físicas:** Pueden usarse junto a sistemas electrónicos de control de acceso.
- **Supervisión del personal de seguridad:** Tener personal capacitado que controle el acceso físico y realice rondas de seguridad para garantizar la protección de la infraestructura.

Ubicación y protección física de los equipos y servidores

Sistemas de vigilancia

- **Cámaras de seguridad:** Colocar cámaras de videovigilancia en puntos estratégicos dentro y fuera de la sala de servidores. Es fundamental que estas cámaras funcionen las 24 horas, los 7 días de la semana, y graben todas las actividades.
- **Monitoreo remoto:** Utilizar un sistema de monitoreo en tiempo real que alerte al personal de seguridad ante cualquier actividad sospechosa o acceso no autorizado.
- **Sensores de movimiento:** Instalar sensores que detecten movimiento en áreas sensibles y que envíen alertas automáticas en caso de intrusiones.

Ubicación y protección física de los equipos y servidores

Protección del hardware

- **Sistemas de detección y extinción de incendios:**
 - **Detectores de humo y calor:** Son esenciales para alertar rápidamente sobre posibles incendios en la sala de servidores.
 - **Sistemas de extinción sin agua:** Utilizar **sistemas de supresión de incendios por gas** (como FM200 o CO2), que son seguros para el equipo electrónico, ya que no dañan los servidores al extinguir el fuego.
 - **Extintores manuales:** Tener extintores adecuados para incendios eléctricos en lugares accesibles.
- **Planes de evacuación y simulacros:** Desarrollar y ensayar periódicamente un plan de evacuación en caso de emergencias, asegurando que todo el personal esté preparado para actuar de manera rápida y eficiente en caso de incendio u otro tipo de amenaza física.

Ubicación y protección física de los equipos y servidores

Condiciones ambientales

- **Control de temperatura:** Los servidores generan calor constante, por lo que es imprescindible mantener un **sistema de refrigeración** eficaz. Esto puede incluir sistemas de **aire acondicionado** dedicados o sistemas de enfriamiento por agua que mantengan la temperatura en un rango seguro (generalmente entre 18°C y 27°C).
- **Control de humedad:** Los niveles de humedad deben mantenerse controlados (normalmente entre el 40% y el 60%) para evitar daños por condensación o electricidad estática.
- **Redundancia de energía:** Implementar **Sistemas de Alimentación Ininterrumpida (SAI)** para asegurar que los servidores continúen funcionando durante un corte de energía, evitando pérdidas de datos o daños en el equipo. Además, los generadores de respaldo son esenciales para evitar interrupciones prolongadas.

Ubicación y protección física de los equipos y servidores

Registro y seguimiento

- **Registro de acceso:** Mantener un registro de todas las personas que ingresan y salen de la sala de servidores, ya sea de forma digital o manual. Este registro debe incluir quién accedió, cuándo lo hizo, y el motivo de su acceso.
- **Auditoría periódica:** Realizar auditorías regulares de los registros de acceso y del estado físico de los equipos para asegurar que no se hayan producido accesos no autorizados ni alteraciones en el entorno.
- **Políticas de cambios y mantenimiento:** Establecer procedimientos claros para cualquier modificación en la infraestructura física, incluyendo el reemplazo o actualización de equipos, y garantizar que todo cambio esté documentado.

Plan de seguridad física

Evaluar los riesgos

- **Identificación de amenazas:** El primer paso es realizar una evaluación exhaustiva para identificar todas las posibles amenazas físicas a las que se enfrenta la organización. Esto puede incluir:
 - Intrusiones no autorizadas.
 - Robos de equipos o datos.
 - Desastres naturales (inundaciones, incendios, terremotos).
 - Vandalismo.
 - Fallas ambientales (temperatura, humedad, cortes de energía).
- **Análisis de vulnerabilidades:** Evaluar las áreas vulnerables, como entradas sin control, ubicaciones no vigiladas o equipos sin protección física adecuada.
- **Impacto y probabilidad:** Clasificar los riesgos según su probabilidad de ocurrencia y el impacto que tendrían sobre la organización.

Plan de seguridad física

Establecer objetivos de seguridad

- **Definir objetivos específicos:** Con base en los riesgos identificados, se deben definir objetivos claros y medibles. Estos podrían incluir:
 - Proteger el acceso físico a las instalaciones críticas.
 - Garantizar la integridad de los equipos y servidores.
 - Evitar la interrupción de los servicios esenciales de TI.
 - Proteger contra desastres naturales y reducir el impacto en las operaciones.
- **Alineación con la estrategia organizacional:** Los objetivos de seguridad física deben estar alineados con la misión y los valores de la organización, así como con su estrategia operativa y regulatoria.

Plan de seguridad física

Diseñar medidas de seguridad

- **Controles de acceso:** Diseñar un sistema que limite el acceso físico a las áreas críticas, utilizando controles de acceso con tarjetas, biometría, llaves y medidas adicionales como la verificación por cámaras de seguridad.
- **Protección perimetral:** Implementar cercas, barreras físicas o puertas de seguridad para controlar y restringir el acceso a las instalaciones.
- **Vigilancia:** Implementar sistemas de videovigilancia y sensores de movimiento para detectar actividad no autorizada o sospechosa en tiempo real.
- **Sistemas de detección y extinción de incendios:** Incluir medidas para detectar y mitigar incendios, como rociadores, sistemas de supresión por gas y detectores de humo.
- **Redundancia energética y protección ambiental:** Asegurar que los equipos cuenten con sistemas de alimentación ininterrumpida (SAI) y control de temperatura y humedad adecuados.

Plan de seguridad física

Establecer políticas y procedimientos

- **Definir protocolos de acceso:** Establecer políticas claras que definan quién tiene acceso a qué áreas, bajo qué condiciones y cómo se gestionarán las credenciales.
- **Procedimientos de respuesta a incidentes:** Establecer procedimientos para que el personal de seguridad y los empleados sepan cómo actuar en caso de intrusiones, incendios, desastres naturales u otras emergencias.
- **Formación del personal:** Capacitar a los empleados sobre las políticas y procedimientos de seguridad física, asegurando que entiendan la importancia de seguir estas medidas.
- **Manejo de registros:** Definir cómo se gestionarán los registros de acceso (logs) y cómo se auditarán regularmente para identificar posibles problemas de seguridad.

Plan de seguridad física

Implementar medidas de seguridad

- **Ejecutar el plan:** Llevar a cabo la implementación de las medidas de seguridad físicas diseñadas, lo que puede incluir la instalación de controles de acceso, cámaras de vigilancia, alarmas y sistemas de extinción de incendios.
- **Asignación de recursos:** Asegurarse de que haya suficiente personal, tecnología y presupuesto para implementar el plan de seguridad de manera efectiva.
- **Pruebas y simulacros:** Realizar simulacros periódicos para asegurar que todo el personal esté preparado para actuar en caso de incidentes, como intrusiones o desastres naturales.

Plan de seguridad física

Monitorear y evaluar

- **Monitoreo continuo:** Establecer un sistema de monitoreo continuo de las medidas de seguridad implementadas, utilizando herramientas como sistemas de videovigilancia y sensores de intrusión.
- **Auditorías regulares:** Realizar auditorías periódicas para verificar que las políticas de acceso y las medidas de seguridad están funcionando según lo previsto.
- **Revisión de incidentes:** Analizar cualquier incidente de seguridad física que ocurra para identificar fallos en las medidas actuales y determinar acciones correctivas.

Plan de seguridad física

Actualizar y mejorar

- **Adaptarse a nuevos riesgos:** Revisar el plan de seguridad física regularmente para asegurarse de que siga siendo efectivo ante nuevos riesgos o cambios en las instalaciones, la infraestructura o la organización.
- **Mejora continua:** Incorporar las lecciones aprendidas de auditorías, incidentes o cambios tecnológicos para mejorar las medidas de seguridad y procedimientos existentes.
- **Evaluación post-implementación:** Evaluar regularmente la efectividad del plan de seguridad mediante simulacros y la recolección de retroalimentación de los empleados.

DATACENTER DE GOOGLE

- https://www.google.com/search?q=como+lo+hacen+entrar+a+datacenter+de+google&sca_esv=f8825106c88e8e1a&sca_upv=1&rlz=1C1UEAD_esES1075ES1075&biw=1536&bih=695&tbm=vid&sxsrf=ADLYWIIhFc6p64oiqeGL4B4uwTsl0RJ_TQ%3A1725636232438&ei=iB7bZtC2Gruji-gPsbe6wA4&oq=COMO+LO+HACEN+ENTRA&gs_lp=Eg1nd3Mtd2l6LXZpZGVvIhNDT01PIExPIEhBQ0VOIEVOVFJBKglIADIFECeY0AFI01ZQmAlYqUxwBHgAkAEAmAGBAaAB6Q-qAQQxNC43uAEDyAEA-AEBmAlZoAKwEMICBBAjGCfCAggQABiABBiiBMICBRAAGIAEwgIOEAAYgAQYsQMYgwEYigXCAGsQABiABBixAxiDAcICChAAGIAEGEMYigXCAGgQABiABBixA8ICCBAAAGBYYHhgPwglGEAAYFhgewglKEAAYFhgKGB4YD8ICBxAhGKABGAqYAwCIBgGSBwQxNi45oAfGggE&sclient=gws-wiz-video#fpstate=ive&vld=cid:52feadd5,vid:XZmGGAbHqa0,st:0

Plan recuperación en caso de desastres

- Un plan de recuperación en caso de desastres (DRP, por sus siglas en inglés) es fundamental para garantizar que una organización pueda restaurar sus operaciones después de un evento inesperado que interrumpa sus sistemas o infraestructura

Plan recuperación en caso de desastres

Evaluación de impacto en el negocio (BIA)

- **Identificación de procesos críticos:** El primer paso es realizar una **Evaluación de Impacto en el Negocio (Business Impact Analysis, BIA)** para identificar los procesos, sistemas y recursos que son esenciales para las operaciones diarias de la organización.
- **Evaluación de impacto financiero y operativo:** Es importante medir el impacto financiero y operativo que tendría la interrupción de estos procesos críticos. Esto incluye pérdidas de ingresos, penalizaciones legales y daños a la reputación.
- **Definir el RTO y RPO:**
 - **RTO (Recovery Time Objective):** El tiempo máximo que puede transcurrir sin que una función crítica esté disponible antes de que tenga un impacto inaceptable.
 - **RPO (Recovery Point Objective):** La cantidad máxima de datos que se pueden perder (en términos de tiempo) antes de que el impacto sea inaceptable.

Plan recuperación en caso de desastres

Estrategias de recuperación

- **Definición de estrategias de recuperación:** Basado en la BIA, se deben diseñar estrategias de recuperación específicas que aborden los diferentes tipos de desastres (desastres naturales, fallos tecnológicos, ataques cibernéticos, entre otros). Estas estrategias incluyen:
 - **Sitios de recuperación:** Puede ser un sitio alternativo donde la empresa pueda trasladar operaciones en caso de que la infraestructura principal sea inutilizada. Los tipos de sitios incluyen:
 - **Sitio caliente:** Una réplica completa del entorno de TI que está listo para ser usado de inmediato.
 - **Sitio frío:** Un espacio físico disponible que necesita ser equipado antes de su uso.
 - **Sitio tibio:** Un sitio con algunos recursos preconfigurados, pero que requiere una puesta en marcha antes de su uso.
 - **Redundancia de datos:** Estrategias para garantizar que los datos estén respaldados y disponibles, como el uso de almacenamiento en la nube, replicación de datos o copias de seguridad fuera del sitio.
 - **Redundancia de hardware y software:** Mantener sistemas y recursos duplicados para que, en caso de fallo, las operaciones puedan ser retomadas rápidamente.

Plan recuperación en caso de desastres

Planes de acción

- **Pasos detallados:** El DRP debe incluir planes de acción detallados que especifiquen **paso a paso** qué hacer en caso de desastre. Estos planes deben incluir:
 - **Instrucciones específicas para el personal:** Definir claramente las responsabilidades de cada equipo y empleado durante la recuperación.
 - **Guías técnicas:** Instrucciones técnicas sobre cómo restaurar sistemas, recuperar datos y reanudar la conectividad.
 - **Prioridades de recuperación:** Clasificar las funciones y sistemas que deben ser restaurados primero, según su importancia para la continuidad del negocio.
 - **Restauración de comunicaciones:** Un plan para restaurar rápidamente la comunicación dentro y fuera de la organización.

Plan recuperación en caso de desastres

Respuesta a emergencias

- **Plan de respuesta inmediata:** Antes de comenzar el proceso de recuperación, es esencial tener un plan de **respuesta a emergencias** que cubra las acciones inmediatas que deben realizarse tras el evento del desastre. Esto incluye:
 - **Protección del personal:** La seguridad de las personas debe ser la máxima prioridad, y el plan debe incluir procedimientos de evacuación, atención médica de emergencia y comunicación interna.
 - **Evaluación inicial del daño:** Un equipo de respuesta debe realizar una evaluación inicial del alcance del daño para entender el impacto en los sistemas y la infraestructura.
 - **Activación del DRP:** Establecer criterios claros para la activación del plan de recuperación en caso de desastres, como el grado de daño y la duración estimada de la interrupción.

Plan recuperación en caso de desastres

Pruebas y mantenimiento

- **Pruebas periódicas:** Realizar pruebas regulares del DRP es esencial para verificar su efectividad y preparar al equipo ante cualquier emergencia. Estas pruebas pueden incluir:
 - **Simulaciones y ejercicios:** Realizar simulacros que simulen diferentes escenarios de desastre (cortes de energía, ciberataques, fallos de hardware) para medir la capacidad de respuesta y ajuste de los tiempos de recuperación.
 - **Pruebas de restauración de datos:** Asegurarse de que las copias de seguridad funcionen correctamente y que los datos críticos puedan restaurarse de manera eficiente.
- **Actualización constante:** El DRP debe ser un documento vivo que se actualice a medida que la organización cambie (nuevas tecnologías, expansión de infraestructuras, cambios en el personal) o surjan nuevas amenazas.
- **Revisión después de incidentes:** Después de cualquier incidente o simulacro, el plan debe revisarse para detectar fallos o áreas de mejora, ajustando los procedimientos según sea necesario.

Sistemas de alimentación ininterrumpida (SAI)



Sistemas de alimentación ininterrumpida (SAI)

- Los **Sistemas de Alimentación Ininterrumpida (SAI)**, también conocidos como **UPS** (por sus siglas en inglés, *Uninterruptible Power Supply*), son dispositivos diseñados para proporcionar energía eléctrica temporalmente a los sistemas críticos en caso de fallos o interrupciones en el suministro eléctrico principal. Su objetivo es evitar la pérdida de datos, daños en los equipos y la interrupción de operaciones críticas

Sistemas de alimentación ininterrumpida (SAI)

Funciones principales de los SAI

- **Suministro de energía ininterrumpida:** Proporcionar energía eléctrica temporal en caso de apagones, permitiendo que los sistemas continúen operando o que se apaguen de manera controlada.
- **Protección contra sobretensiones:** Filtrar picos de tensión y sobretensiones que puedan dañar los equipos.
- **Regulación de la tensión:** Estabilizar las variaciones en el suministro eléctrico (caídas de tensión, fluctuaciones) para evitar daños en los dispositivos conectados.
- **Monitoreo y alerta:** Algunos SAI avanzados ofrecen la capacidad de monitorear el estado de la energía y generar alertas automáticas cuando se produce una falla en el suministro.

Sistemas de alimentación ininterrumpida (SAI)

- **Tipos de SAI**
- Existen tres tipos principales de SAI, cada uno con diferentes niveles de protección y adecuación según las necesidades de los equipos críticos:
- **SAI offline (standby):**
 - Es el tipo más básico de SAI. Proporciona energía a los dispositivos cuando ocurre un corte eléctrico o se produce una fluctuación extrema de tensión.
 - Mientras el suministro de energía es estable, los dispositivos están conectados directamente a la corriente. En caso de fallo, el SAI cambia a la batería interna en milisegundos.
 - Es adecuado para equipos de oficina o dispositivos no críticos.



Sistemas de alimentación ininterrumpida (SAI)



SAI interactivo (line-interactive):

- Proporciona una protección mayor que el SAI offline, ya que regula el voltaje de manera continua sin cambiar a la batería, a menos que haya una interrupción total.
- Utiliza un **autotransformador** que ajusta las pequeñas variaciones de voltaje, estabilizando la energía que reciben los equipos.
- Es ideal para servidores, sistemas de telecomunicaciones o equipos que necesitan más estabilidad.

Sistemas de alimentación ininterrumpida (SAI)



SAI en línea (online/doble conversión):

- Este tipo ofrece la mayor protección, ya que siempre mantiene los equipos conectados a la energía a través de su batería, garantizando un suministro estable y filtrado en todo momento.
- Realiza una **doble conversión**: convierte la energía de CA (corriente alterna) a CC (corriente continua) y luego de nuevo a CA, eliminando cualquier fluctuación o interrupción antes de llegar a los equipos.
- Es ideal para sistemas críticos como centros de datos, servidores de alta disponibilidad y equipos médicos sensibles.

Listas de control de acceso

¿Qué son las ACL?

- Las ACL son conjuntos de reglas que definen el acceso permitido o denegado a los recursos de un sistema. Estos recursos pueden ser archivos, carpetas, dispositivos, redes o incluso aplicaciones. Las ACL permiten establecer permisos específicos para distintos usuarios o grupos de usuarios, controlando así las acciones que pueden realizar sobre un recurso.

Listas de control de acceso

Listas de Control de Acceso de Archivos (FACL)

- **Descripción:** Las FACL (File Access Control List) son utilizadas en sistemas de archivos para definir permisos de acceso detallados para archivos y directorios. Este tipo de ACL permite establecer permisos específicos para usuarios individuales o grupos sobre archivos o carpetas.
- **Características:**
 - Permiten controlar qué usuarios o grupos pueden leer, escribir, o ejecutar un archivo o directorio.
 - Son más flexibles que los permisos tradicionales, ya que permiten asignar permisos a varios usuarios y grupos de forma granular.

Listas de control de acceso

Listas de Control de Acceso de Red (RACL)

- **Descripción:** Las RACL (Network Access Control List) se utilizan en dispositivos de red, como routers, switches y firewalls, para controlar el tráfico de red. Permiten establecer reglas que filtran paquetes de red basados en direcciones IP, puertos y protocolos.
- **Características:**
 - Permiten bloquear o permitir tráfico en función de criterios como la **IP de origen o destino**, **puertos** o el **protocolo** utilizado (TCP, UDP).
 - Se utilizan comúnmente en routers y firewalls para gestionar el tráfico entrante y saliente en una red, asegurando que solo el tráfico permitido pueda pasar.

Listas de control de acceso

Listas de Control de Acceso a Nivel de Objeto (OACL)

- **Descripción:** Las OACL (Object Access Control List) se aplican a bases de datos o aplicaciones que gestionan su propia seguridad interna. Este tipo de ACL controla el acceso a **objetos** específicos, como tablas, vistas, procedimientos almacenados o funciones dentro de la base de datos.
- **Características:**
 - Permiten definir permisos detallados para usuarios o grupos de usuarios sobre objetos específicos dentro de una base de datos.
 - Se utilizan comúnmente en bases de datos relacionales (como **SQL Server**, **MySQL**, **Oracle**), donde los administradores pueden controlar qué usuarios tienen acceso a determinados objetos.

Plan de Contingencia y Continuidad de Negocio

